

# **IT-Sicherheitsrichtlinie des Klinikums**

Klinikum Musterstadt · Abteilung IT · Version 2026.1 (fiktives Beispiel)

# Inhalt

1. Geltungsbereich und Ansprechpartner ..... Seite 3
2. Passwortregeln ..... Seite 4
3. Umgang mit Patientendaten ..... Seite 5
4. Phishing und verdächtige E-Mails ..... Seite 6
5. USB-Datenträger ..... Seite 7
6. Cloud-Dienste und Dateiaustausch ..... Seite 8
7. Private Geräte und WLAN ..... Seite 9
8. Arbeitsplatz und Ausdrucke ..... Seite 10
9. Sicherheitsvorfälle melden ..... Seite 11
10. Pflichtschulung ..... Seite 12

# **1. Geltungsbereich und Ansprechpartner**

Diese Richtlinie gilt für alle Mitarbeitenden, Auszubildenden, Gastärztinnen und Gastärzte sowie externe Dienstleister. Ansprechpartner für Fragen der Informationssicherheit ist die oder der Informationssicherheitsbeauftragte (ISB), erreichbar unter [isb@klinikum-musterstadt.de](mailto:isb@klinikum-musterstadt.de). Verstöße können arbeitsrechtliche Folgen haben.

## **2. Passwortregeln**

Passwörter müssen mindestens zwölf Zeichen lang sein und werden alle 180 Tage geändert. Sie dürfen nicht weitergegeben oder notiert werden. Vergessene Windows-Passwörter setzt man über den Self-Service-Passwortreset im Intranet zurück; dafür muss eine Mobilnummer hinterlegt sein.

### **3. Umgang mit Patientendaten**

Patientendaten unterliegen der ärztlichen Schweigepflicht und der DSGVO. Sie dürfen nicht über private E-Mail-Konten oder Messenger wie WhatsApp versendet werden und nur so lange gespeichert werden, wie es für die Behandlung nötig ist.

## **4. Phishing und verdächtige E-Mails**

Verdächtige E-Mails werden über die Schaltfläche „Phishing melden“ in Outlook weitergeleitet. Links und Anhänge solcher E-Mails dürfen nicht geöffnet werden. Wurde bereits geklickt, sofort den IT-Servicedesk unter 4444 anrufen, damit das Gerät isoliert werden kann.

## **5. USB-Datenträger**

USB-Anschlüsse sind für Speichermedien gesperrt. Ausnahmen genehmigt die oder der Informationssicherheitsbeauftragte; dann dürfen nur verschlüsselte, vom Klinikum ausgegebene USB-Sticks verwendet werden.

## **6. Cloud-Dienste und Dateiaustausch**

Private Cloud-Dienste wie Dropbox, Google Drive oder WeTransfer sind für dienstliche Daten verboten. Für den Dateiaustausch mit externen Partnern steht die klinikeigene Nextcloud zur Verfügung; Freigabelinks laufen nach 14 Tagen ab.

## **7. Private Geräte und WLAN**

Private Smartphones, Tablets und Laptops dürfen nicht mit dem Kliniknetz verbunden werden. Das Gäste-WLAN „Klinikum-Gast“ darf privat genutzt werden, bietet aber keinen Zugriff auf Kliniksysteme.

## **8. Arbeitsplatz und Ausdrücke**

Beim Verlassen des Arbeitsplatzes wird der Bildschirm mit Windows + L gesperrt. Ausdrücke mit Patientendaten dürfen nicht offen liegen bleiben und werden in den verschlossenen Datenschutztonnen entsorgt.

## **9. Sicherheitsvorfälle melden**

Jeder Verdacht auf einen Sicherheitsvorfall, etwa ein verlorenes Diensthandy, eine Virenmeldung oder ein unbekanntes Gerät im Netzwerk, ist sofort dem IT-Servicedesk unter 4444 zu melden, außerhalb der Servicezeiten über die Telefonzentrale. Verlorene Geräte werden aus der Ferne gesperrt und gelöscht.

## **10. Pflichtschulung**

Alle Mitarbeitenden absolvieren jährlich die E-Learning-Pflichtschulung Informationssicherheit und Datenschutz im Fortbildungsportal. Die Teilnahme wird der oder dem Vorgesetzten gemeldet; neue Mitarbeitende absolvieren sie in den ersten vier Wochen.